



Capesand Exploit Kit's Tools Seen in KurdishCoder Campaign

In November 2019, we published the analysis for new exploit kit Capesand, and further analysis of the indicators of compromise (IoCs) showed these samples were using obfuscation tools that made them virtually undetectable.

By: William Gamazo Sanchez, Joseph C Chen

December 04, 2019

Read time: 4 min (1180 words)



In November 2019, we [published a blog](#) analyzing an exploit kit we named Capesand that exploited Adobe Flash and Microsoft Internet Explorer flaws. During our analysis of the indicators of compromise (IoCs) in the deployed samples that were infecting the victim's machines, we noticed some interesting characteristics: notably that these samples were making use of obfuscation tools that made them virtually undetectable.

After some data collection we found more than 300 samples that correlate to the mentioned indicators that were recently very active. Our first detections occurred in August, with the campaign itself still ongoing (having occasional spikes in between). We saw a rising usage of tools that provide fully-undetectable obfuscation capabilities – signifying that the authors behind the samples designed their malware variants to be as stealthy as possible. We decided to name the potential campaign associated with these IoCs “KurdishCoder”, based on the property name of an assembly module found in one of the samples.



We found that there are multiple layers of obfuscation using a combination of two tools: the .NET protectors ConfuserEx and Cassandra (CyaX). Both of these tools are used in combination to provide an array of fully undetectable capabilities to the deployed njRat malware variant.

Examining the Capesand samples

The simplified diagram taken from the previous blog shows the combination of ConfuserEx and Cassandra via the second layer of obfuscation protection, which involves the DLL CyaX_Sharp Assembly (both CyaX_Sharp and CyaX are part of the Cassandra protector).

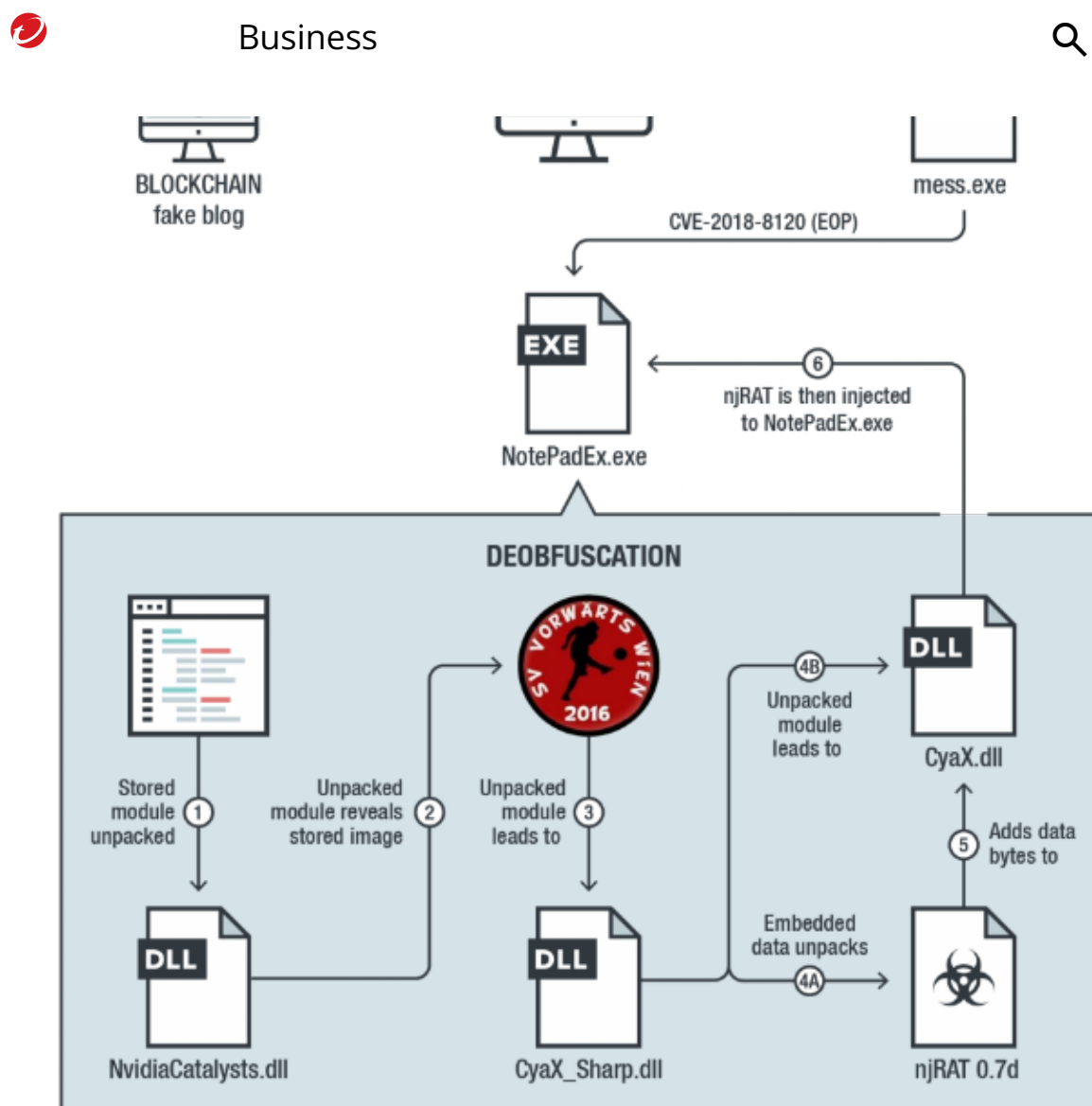


Figure 1. The infection chain for Capesand that also shows the obfuscation mechanisms

For this particular sample, CyaX_Sharp is obfuscated with a customized version of ConfuserEx. The following image shows an assembly module property that was generated for this sample.



Figure 2. The generated assembly module property

The module's property name is "KurdishCoderProducts", with a value shown to be "ConfuserEx v1.0.0-custom". To understand where this value is coming from, let's take a look at the open-source ConfuserEx tool to see how the values are created. From there, we can establish a hypothesis as to their source.

A closer look at ConfuserEx's functions

While ConfuserEx is able to apply multiple transformations to the target binary, we are interested in two particular functions that we can use for correlation:

1. Source code building.

ConfuserEx is an open-source tool with multiple versions hosted on Github.

By examining **one of the community-supported versions**, we can see there is a tool to build ConfuserEx from the command line. This build command line has **a function** to update the final binary versions based on the last Git-tagged version. However, if ConfuserEx is built outside Git, the version update tool will just generate the value "version-custom" as shown below.



Business



```
tag = tag ?? "v" + ver + "-custom";

string template = Path.Combine(dir, "GlobalAssemblyInfo.Template.cs");
string output = Path.Combine(dir, "GlobalAssemblyInfo.cs");
```

Figure 3. Code taken from a ConfuserEx version created outside GIT

Since the string “ConfuserEx v1.0.0-custom” is present in the module property: [module: KurdishCoderProducts(“ConfuserEx v1.0.0-custom”)], we can surmise that the version of ConfuserEx that was used for CyaX_Sharp was indeed built outside of Git.

2. Watermarking

When ConfuserEx performs its obfuscation routine, one of the operations creates a watermark – a unique identifier within the software--that is present in the final binary. The watermarking technique is implemented through the module attributes of the assembly. The following source code screenshot shows how this is implemented.

```
context.Logger.Debug("Watermarking...");
foreach (ModuleDefMD module in context.Modules) {
    TypeRef attrRef = module.CorLibTypes.GetTypeRef("System", "Attribute");
    var attrType = new TypeDefUser("", "ConfusedByAttribute", attrRef);
    module.Types.Add(attrType);
    marker.Mark(attrType, null);
}
```

Figure 4. Code showing how the watermarking is performed via the module attributes of the assembly



Business



... obfuscation...

```

9
10 using System;
11
12 [module: ConfusedBy("ConfuserEx v1.0.0")]
13

```

Figure 5. Testing a sample binary using ConfuserEx

There are two important aspects to this attribute: first, it is hardcoded as a string constant and second, its value is presented in clear text in the final binary as the following image shows.

```

zeNULm_DictionarySizeCheckNULm_PosAlignDecoderNULm
tsPropertiesNULSetDecoderPropertiesNULGetLenToPosS
Nm_HighCoderNULm_NumPosStatesNULCreateNULLiteralDe
ateNULDecodeNormalNULDecodeWithMatchByteNULDecoder
NUL_windowSizeNULFlushNULCopyBlockNULPutByteNULGet
ateShortRepNULIsCharStateNULConfusedByAttributeNUL
rightAttributeNULAssemblyProductAttributeNULComVisi
gNULAssemblyFileVersionAttributeNULGuidAttributeNUL

```

Figure 6. The default attribute shown in clear text in the final binary

We now have solid evidence that CyaX_Sharp was obfuscated using a modified version of ConfuserEx. Next, let's look for the attribute indicator, starting with the CyaX assembly used in the NotepadEx attack.

Cassandra Protector: CyaX

After inspection we noticed that this version of CyaX was similarly notable due to two characteristics.



Business



```
NULVTMy.SettingsNULNUL'NULNULNULIEi%4SOHNULNULNUL'NULNULNULlSys
Version=2.0.0.0, Culture=neutral,
PublicKeyToken=b77a5c561934e089#System.Resources.RuntimeResourceSe
NULNULNULNULNULNUL^#š]NULNULNULNULSTXNULNULNULFSOHNULNULDLE(
:\Users\Cassandra\Desktop\Premium\CyaX\CyaX\obj\Debug\CyaX.pdbNULN
NULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNUL
NULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNULNUL
```

Figure 7. The leaked debug symbols paths

The second indicator has to do with one of the methods of CyaX which was modified -- specifically the one injecting the binary in memory.

The following image shows the modified function name.

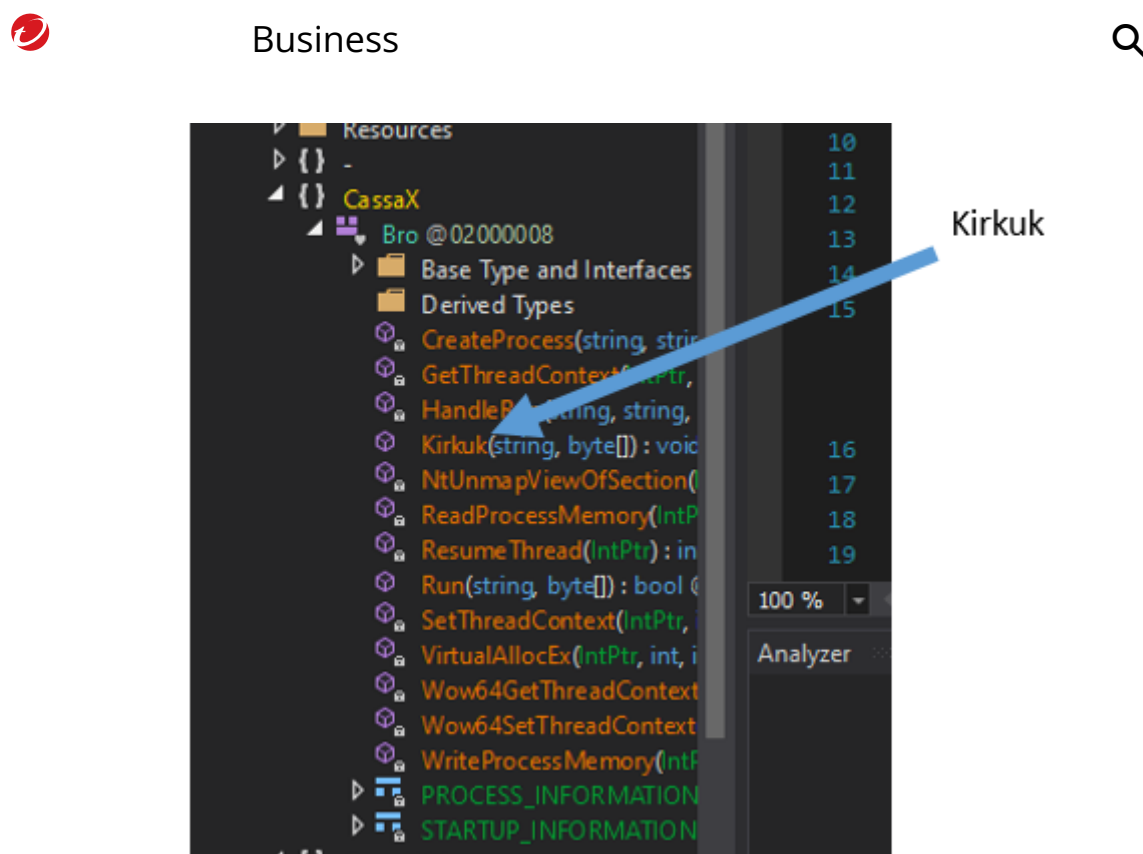


Figure 8. The modified method which was renamed to Kirkuk, which is also a name of a city in Iraq

What other payloads are using KurdishCoder?

Analysis of some of the captured samples reveals the different payloads being used (as shown in the table below). Note that this does not cover all the samples – it is possible that other payloads are being deployed as well.

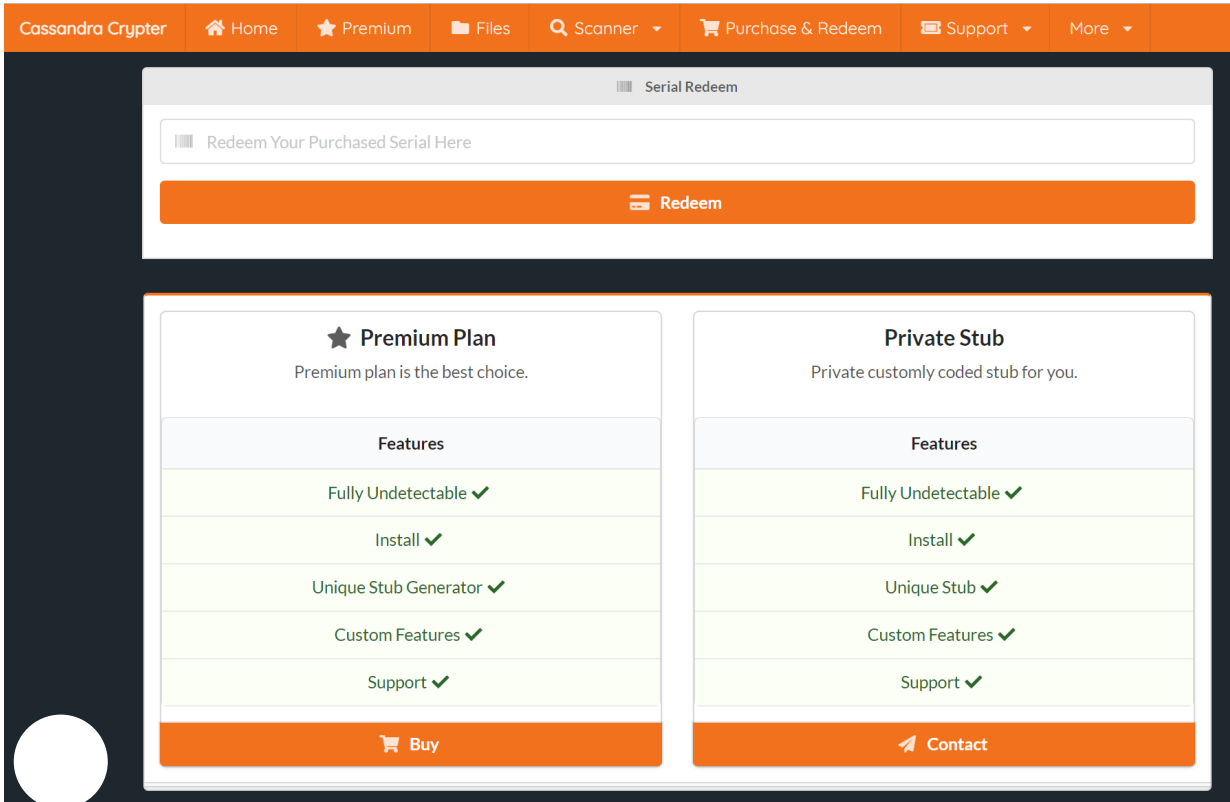
Sample	Payload	KurdishCoderMainSample	KurdishCoder_Cy
CustomIncreaseX	phoenix_keylogger	Yes	Yes
NotePadEx	Njrat	No	Yes
Translation	Agent Tesla	Yes	Yes

 Business 			
AnimalGames	Hawkeye Rebord Keylogger	Yes	Yes

Table 1. The different samples organized name, payload delivered and the fully-undetectable stages where the attribute “KurdishCoderProduction” is present

Cassandra Crypter

We think one of the possible sources of the customized ConfuserEx is the online service Cassandra Crypter, which offers two kinds of subscription plans: The Premium Plan and the Private Stub. The Premium Plan requires payment and works automatically, while the Private Stub requires the user to contact the support from the service for further personalization.



The screenshot displays the Cassandra Crypter website. The top navigation bar includes links for Home, Premium, Files, Scanner, Purchase & Redeem, Support, and More. The main content area features a 'Serial Redeem' section with a text input field for redeeming a serial and a 'Redeem' button. Below this, there are two columns for subscription plans. The 'Premium Plan' is described as the best choice and lists features: Fully Undetectable, Install, Unique Stub Generator, Custom Features, and Support, with a 'Buy' button. The 'Private Stub' is described as a private custom-coded stub and lists the same features, with a 'Contact' button.

Plan	Features	Action
Premium Plan	Fully Undetectable ✓ Install ✓ Unique Stub Generator ✓ Custom Features ✓ Support ✓	Buy
Private Stub	Fully Undetectable ✓ Install ✓ Unique Stub ✓ Custom Features ✓ Support ✓	Contact



The combination of ConfuserEx and CyaX (Cassandra protector) seems to be unique and customized based on the indicators mentioned earlier.

While we don't have definitive evidence that the use of these tools are part of a single campaign, we think the analyzed samples are related to a specific campaign. Note that the KurdishCoder indicator was spotted also by the Italian Computer Emergency Response Team - Pubblica Amministrazione (CERT-PA), which they **reported as a single incident**.

As with Capesand, we will be monitoring the use of the tools mentioned in this blog entry for any future developments and updates.

Trend Micro Solutions

A proactive, multilayered approach to security is key against a wide range of threats— from the gateway, endpoints, networks, and servers. **Trend Micro™ endpoint security** has vulnerability protection that shields endpoints from identified and unknown vulnerability exploits even before patches are even deployed. Trend Micro's endpoint solutions such as **Trend Micro™ Smart Protection Suites** and **Worry-Free™ Business Security** protect end users and businesses from these threats by detecting and blocking malicious files and all related malicious URLs.

Indicators of Compromise (IoCs)

Indicator	Attribution
068d32a43191dc0164b600b85a1621be0154504fd477167422ff4a8fb3406d73	AnimalGame
07b1e156caac1157707ffe38266dc60abadc488226b4f41d67f23eac98dd917b0	CustomIncre
b1b1cc9a4292fc5cc4ae5371ea1615ec6e49ebaf061dc4eccde84a6f96d95747c	NotePadEx



Business



02f2369b58fbb2ba1df2c799b73842880a4874c32c1514a0d8956133be026ade

SimpleGame

Tags

[Mobile](#) | [APT & Targeted Attacks](#) | [Research](#)

Authors

William Gamazo Sanchez

Sr. Threat Researcher

Joseph C Chen

Threat Researcher

[CONTACT US](#)

Related Articles



Business



[Earth Koshchei Coopts Red Team Tools in Complex RDP Attacks](#)

[See all articles >](#)

Experience our unified
platform for free

[Claim your 30-day trial](#)



Resources



Support



About Trend





Business



Trend Micro - United States (US)

225 East John Carpenter Freeway
Suite 1500
Irving, Texas 75062

Phone: +1 (817) 569-8900

Select a country / region

United States



[Privacy](#)

[Legal](#)

[Accessibility](#)

[Terms of Use](#)

[Site map](#)

Copyright ©2024 Trend Micro Incorporated. All rights reserved